

Chương 4

VẤN ĐỀ AN NINH TRONG TMĐT

4.1 Vai trò của an ninh

Xây dựng chính sách về an ninh an toàn mạng và yêu cầu mọi người phải chấp hành có ý nghĩa quan trọng trong việc xây dựng ý thức và thể chế hóa hoạt động bảo vệ an ninh cho thương mại điện tử.

Chính sách này thường bao gồm các nội dung sau:



4.1 Vai trò của an ninh

- **Quyền truy cập:** xác định ai được quyền truy cập vào hệ thống, mức độ truy cập và ai giao quyền truy cập
- **Bảo trì hệ thống:** ai có trách nhiệm bảo trì hệ thống như việc sao lưu dữ liệu, kiểm tra an toàn định kỳ, kiểm tra tính hiệu quả các biện pháp an toàn,...
- **Bảo trì nội dung và nâng cấp dữ liệu:** ai có trách nhiệm với nội dung đăng tải trên mạng intranet, internet và mức độ thường xuyên phải kiểm tra và cập nhật những nội dung này
- **Cập nhật chính sách an ninh thương mại điện tử:** mức độ thường xuyên và ai chịu trách nhiệm cập nhật chính sách an ninh mạng và các biện pháp đảm bảo việc thực thi chính sách đó.

4.2 Khái niệm và định nghĩa

An ninh thương mại điện tử là quá trình làm giảm thiểu và hạn chế các rủi ro có thể xảy đến trong thương mại điện tử liên quan đến các vấn đề về thủ tục, chính sách, pháp luật và đặc biệt là công nghệ.

Một ví dụ về an ninh thương mại điện tử điển hình là việc doanh nghiệp đảm bảo an toàn trước các lỗi, mã độc mà do tin tặc gây ra.

An toàn luôn chỉ mang tính tương đối, bất cứ hệ thống an toàn nào cũng có thể bị phá vỡ. An toàn là một chuỗi liên kết và thường bị đứt ở những điểm yếu nhất

4.2 Khái niệm và định nghĩa

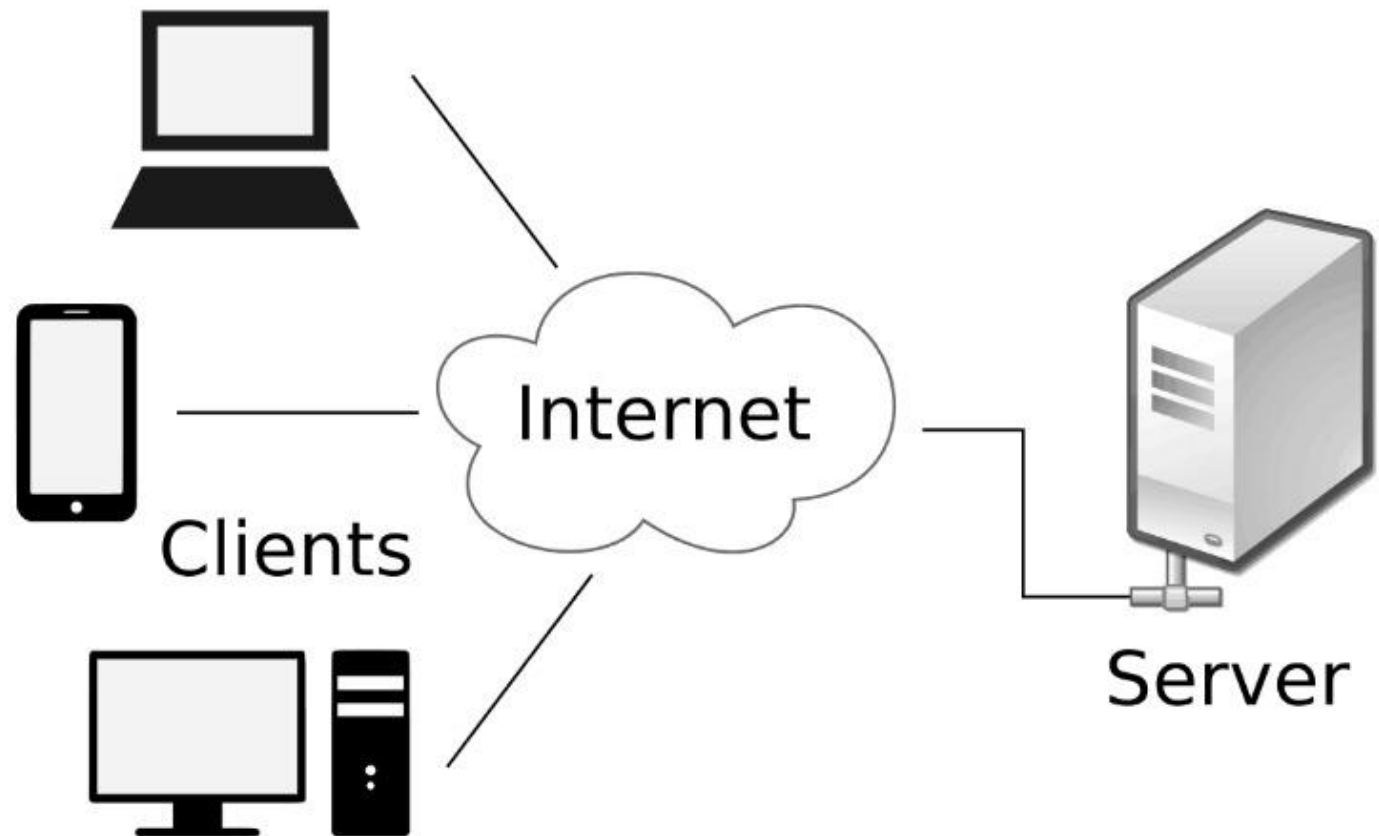
Các khía cạnh của an toàn TMĐT

- Tính toàn vẹn: khả năng đảm bảo an toàn cho các thông tin được hiển thị trên Web site hoặc các thông tin được chuyển đi trên Internet
- Chống phủ định: khả năng đảm bảo các bên tham gia giao dịch TMĐT không phủ định các hành động giao dịch trực tuyến mà họ đã thực hiện
- Tính xác thực: khả năng đảm bảo nhận biết các đối tác tham gia giao dịch trực tuyến trên Internet
- Tính tin cậy: khả năng đảm bảo không ai có thể truy cập các thông điệp và dữ liệu có giá trị
- Tính riêng tư: khả năng đảm bảo kiểm soát việc sử dụng các thông tin cá nhân mà khách hàng cung cấp về chính bản thân họ
- Tính sẵn dùng: khả năng đảm bảo các chức năng của một web site thương mại điện tử được thực hiện đúng như mong đợi

4.2 Khái niệm và định nghĩa

Ba điểm cần bảo mật quan trọng nhất

- Client
- Server
- Kênh truyền dữ liệu



4.3 Phân loại rủi ro và nguy cơ

Rủi ro trong thương mại điện tử có thể chia thành bốn nhóm cơ bản sau:

- Nhóm rủi ro dữ liệu
- Nhóm rủi ro về công nghệ
- Nhóm rủi ro về thủ tục quy trình giao dịch của tổ chức
- Nhóm rủi ro về luật pháp và các tiêu chuẩn công nghiệp

Các nhóm rủi ro này không hoàn toàn độc lập với nhau mà đôi khi chúng đồng thời cùng xảy đến và không xác định tách bạch rõ ràng được. Nếu các rủi ro này đồng thời xảy ra, thiệt hại đối với tổ chức có thể rất lớn cả về uy tín, thời gian và chi phí đầu tư để khôi phục hoạt động trở lại bình thường.

4.3 Phân loại rủi ro và nguy cơ

Một số dạng tấn công chính vào các website thương mại điện tử:

- Virus
- Tin tặc (hacker) và các chương trình phá hoại (cybervandalism)
- Rủi ro về gian lận thẻ tín dụng
- Tấn công từ chối dịch vụ
- Kẻ trộm trên mạng (sniffer)
- Phishing – “kẻ giả mạo”



4.3 Phân loại rủi ro và nguy cơ

Virus

Virus tấn công vào thương mại điện tử thường gồm 3 loại chính: virus ảnh hưởng tới các tệp (file) chương trình (gắn liền với những file chương trình, thường là .COM hoặc .EXE), virus ảnh hưởng tới hệ thống (đĩa cứng hoặc đĩa khởi động), và virus macro.

Virus macro là loại virus phổ biến nhất, chiếm từ 75% đến 80% trong tổng số các virus được phát hiện. Đây là loại virus đặc biệt chỉ nhắm vào các tệp ứng dụng soạn thảo, chẳng hạn như các tệp ứng dụng của MS Word, Excel và Power Point .

Khi người sử dụng mở các tài liệu bị nhiễm virus trong các chương trình ứng dụng, virus này sẽ tự tạo ra các bản sao và nhiễm vào các tệp chứa đựng các khuôn mẫu của ứng dụng, để từ đó lây sang các tài liệu khác.

4.3 Phân loại rủi ro và nguy cơ

Virus

Các loại virus có thể gây ra những tác hại nghiêm trọng, đe dọa tính toàn vẹn và khả năng hoạt động liên tục, thay đổi các chức năng, thay đổi các nội dung dữ liệu hoặc đôi khi làm ngưng trệ toàn bộ hoạt động của nhiều hệ thống trong đó có các website thương mại điện tử.

Nó được đánh giá là mối đe dọa lớn nhất đối với an toàn của các giao dịch thương mại điện tử hiện nay

4.3 Phân loại rủi ro và nguy cơ

Tin tặc (hacker) và các chương trình phá hoại (cybervandalism)

Tin tặc là thuật ngữ dùng để chỉ những người truy cập trái phép vào một website, một cơ sở dữ liệu hay hệ thống thông tin. Mục tiêu của các hacker rất đa dạng. Có thể là hệ thống dữ liệu của các website thương mại điện tử, hoặc với ý đồ nguy hiểm hơn chúng có thể sử dụng các chương trình phá hoại (cybervandalism) nhằm gây ra các sự cố, làm mất uy tín hoặc phá hủy website trên phạm vi toàn cầu.



4.3 Phân loại rủi ro và nguy cơ

Rủi ro về gian lận thẻ tín dụng

Trong TMĐT mỗi đe dọa lớn nhất là bị “mất” (hay bị lộ) các thông tin liên quan đến thẻ tín dụng hoặc các thông tin giao dịch sử dụng thẻ tín dụng trong quá trình thực hiện các giao dịch mua sắm qua mạng và các thiết bị điện tử.



4.3 Phân loại rủi ro và nguy cơ

Rủi ro về gian lận thẻ tín dụng

Các tệp chứa dữ liệu thẻ tín dụng của khách hàng thường là những mục tiêu hấp dẫn đối với tin tặc khi tấn công vào website thương mại điện tử.

Hơn thế, những tên tội phạm có thể đột nhập vào các cơ sở dữ liệu của website thương mại điện tử để lấy cắp các thông tin của khách hàng như tên, địa chỉ, điện thoại... với những thông tin này chúng có thể mạo danh khách hàng thiết lập các khoản tín dụng mới nhằm phục vụ những mục đích phi pháp.

4.3 Phân loại rủi ro và nguy cơ

Tấn công từ chối dịch vụ

- Tấn công từ chối dịch vụ (DOS - Denial Of Service attack, DDOS – Distributed DOS hay DR DOS) là kiểu tấn công khiến một hệ thống máy tính hoặc một mạng bị quá tải, dẫn tới không thể cung cấp dịch vụ hoặc phải dừng hoạt động.
- Sơ khai nhất là hình thức DoS (Denial of Service), lợi dụng sự yếu kém của giao thức TCP, tiếp đến là DDoS (Distributed Denial of Service) - tấn công từ chối dịch vụ phân tán, và gần đây là DRDoS - tấn công theo phương pháp phản xạ phân tán (Distributed Reflection Denial of Service).

4.3 Phân loại rủi ro và nguy cơ

Tấn công từ chối dịch vụ

- Những cuộc tấn công DoS có thể là nguyên nhân khiến cho mạng máy tính ngừng hoạt động và trong thời gian đó, người sử dụng sẽ không thể truy cập vào các website thương mại điện tử.
- Những tấn công này cũng đồng nghĩa với những khoản chi phí rất lớn vì trong thời gian website ngừng hoạt động, khách hàng không thể thực hiện các giao dịch mua bán. Đồng thời, sự gián đoạn hoạt động này sẽ ảnh hưởng đến uy tín và tiếng tăm của doanh nghiệp, những điều không dễ dàng gì lấy lại được.
- Mặc dù những cuộc tấn công này không phá hủy thông tin hay truy cập vào những vùng cấm của máy chủ nhưng tạo ra phiền toái, gây trở ngại cho hoạt động của nhiều doanh nghiệp.

4.3 Phân loại rủi ro và nguy cơ

Kẻ trộm trên mạng (sniffer)

- Kẻ trộm trên mạng (sniffer) là một dạng của chương trình theo dõi, nghe trộm, giám sát sự di chuyển của thông tin trên mạng.
- Khi sử dụng vào những mục đích hợp pháp, nó có thể giúp phát hiện ra những yếu điểm của mạng, nhưng ngược lại, nếu sử dụng vào các mục đích phi pháp, các phần mềm ứng dụng này sẽ trở thành các mối hiểm họa lớn và rất khó có thể phát hiện.
- Kẻ trộm sử dụng các phần mềm này nhằm lấy cắp các thông tin có giá trị như thư điện tử, dữ liệu kinh doanh của các doanh nghiệp, các báo cáo mật...từ bất cứ nơi nào trên mạng.
- Xem lén thư điện tử là một dạng mới của hành vi trộm cắp trên mạng.

4.3 Phân loại rủi ro và nguy cơ

Phishing – “kẻ giả mạo”

Phishing là một loại tội phạm công nghệ cao sử dụng email, tin nhắn pop-up hay trang web để lừa người dùng cung cấp các thông tin cá nhân nhạy cảm như thẻ tín dụng, mật khẩu, số tài khoản ngân hàng.

Kẻ giả mạo thường hướng tới phishing những khách hàng của ngân hàng và người tiêu dùng thường mua sắm trực tuyến. Những thông tin ăn cắp được sẽ được kẻ giả mạo dùng để truy cập với mục đích xấu, nếu là thông tin về tài khoản thanh toán thì sẽ dùng vào mục đích mua hàng hoặc rút tiền.



4.4 Ngăn ngừa và bảo vệ



Kế hoạch an ninh

An toàn giao dịch

Bảo vệ hệ thống

4.4.1 Xây dựng kế hoạch an ninh

Việc xây dựng kế hoạch an ninh thương mại điện tử cho doanh nghiệp bao gồm 4 giai đoạn sau:

- Giai đoạn đánh giá:
- Giai đoạn lên kế hoạch
- Giai đoạn thực thi
- Giai đoạn giám sát



4.4.1 Xây dựng kế hoạch an ninh

Giai đoạn đánh giá:

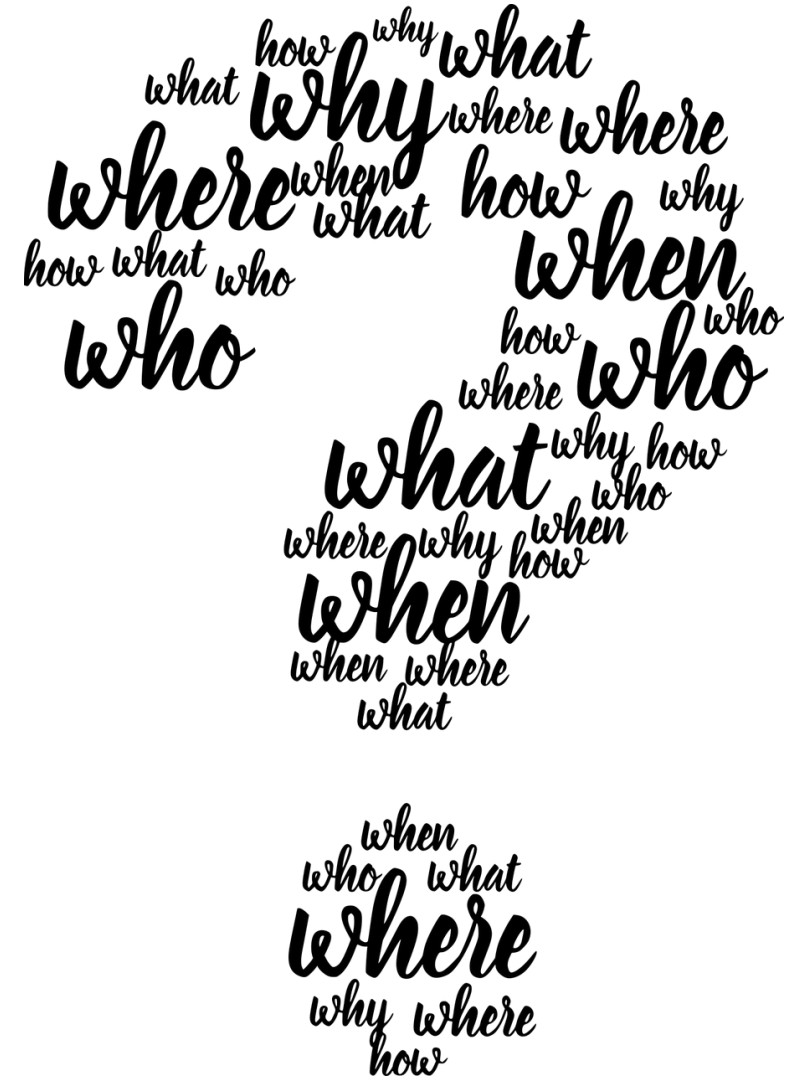
- Xác định các mối đe dọa: đa số những vụ xâm phạm an ninh trái phép là do sự can thiệp trực tiếp hay gián tiếp của con người các hệ thống và những người có quyền truy cập tới tài sản phải được định rõ như giám đốc IT, nhân viên, các nhà tư vấn,... Khả năng mối đe dọa trở thành hiện thực cũng cần được đánh giá.
- Xác định hình thức thiệt hại: ví dụ các thông tin quan trọng có thể bị sửa đổi hoặc đánh cắp bởi các cá nhân, hoặc có thể bị phá hủy do bị tấn công.

4.4.1 Xây dựng kế hoạch an ninh

Giai đoạn lên kế hoạch:

Xác định rõ ràng đe dọa nào cần phải chống đỡ và giải pháp tương ứng cần được tiến hành, thời gian cụ thể và người chịu trách nhiệm triển khai.

Đánh giá và lựa chọn các giải pháp phù hợp.



4.4.1 Xây dựng kế hoạch an ninh

Giai đoạn thực thi:

Các công nghệ đặc thù có thể được chọn để chống đỡ với các nguy cơ dễ xảy ra nhất. Việc lựa chọn công nghệ dựa vào những định hướng đã được nêu ra ở giai đoạn lập kế hoạch.

Ngoài những công nghệ đặc thù, các phần mềm an ninh từ những nhà cung cấp khác cũng có thể được lựa chọn.

4.4.1 Xây dựng kế hoạch an ninh

Giai đoạn giám sát:

Xác định những biện pháp nào mang lại thành công, những biện pháp nào không hiệu quả cần thay đổi, liệu có những mối đe dọa mới xuất hiện hay có những cải tiến hoặc thay đổi gì trong công nghệ, hoặc có những tài sản nào khác của doanh nghiệp cần bảo đảm an ninh.



4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Biện pháp hữu hiệu nhất hiện nay trong việc đảm bảo tính xác thực là sử dụng hạ tầng khóa công khai (PKI – Public Key Infrastructure) trong đó có sử dụng các thiết bị kỹ thuật, hạ tầng và quy trình để ứng dụng việc mã hóa, chữ ký số và chứng chỉ số.



4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Kỹ thuật mã hoá thông tin:

Mã hoá thông tin là quá trình chuyển các văn bản hay các tài liệu gốc thành các văn bản dưới dạng mật mã bằng cách sử dụng một thuật mã hóa.

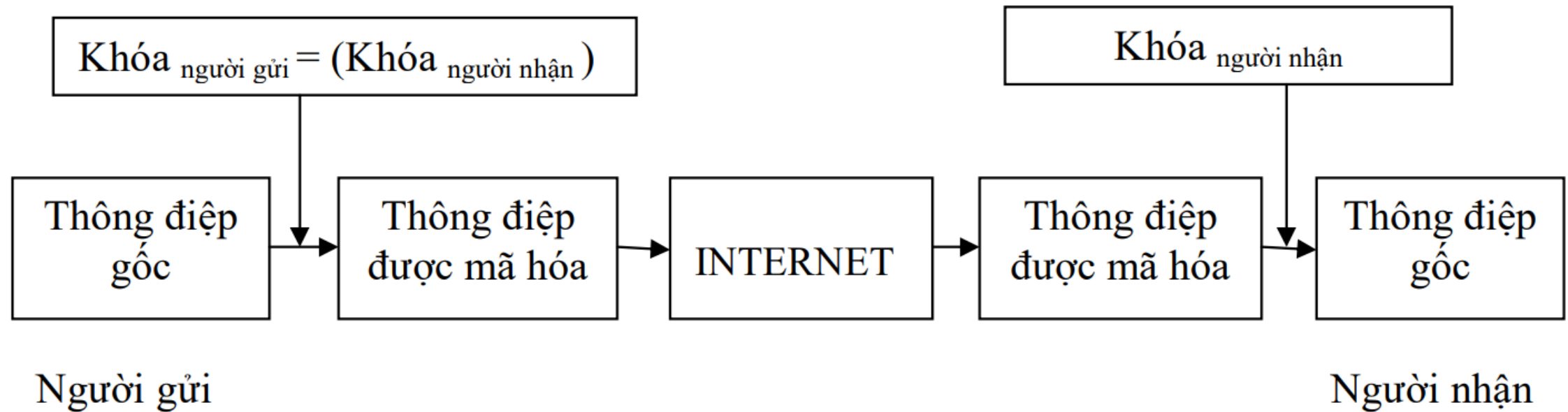
Giải mã là quá trình văn bản dạng mật mã được chuyển sang văn bản gốc dựa trên mã khóa.

Mục đích của kỹ thuật mã hoá nhằm đảm bảo an toàn cho các thông tin được lưu giữ và đảm bảo an toàn cho thông tin khi truyền phát.

Có hai kỹ thuật cơ bản thường được sử dụng để mã hoá thông tin là mã hoá “khóa đơn” sử dụng một “khóa bí mật” và mã hoá kép sử dụng hai khóa gồm “khóa công khai” và “khóa bí mật”.

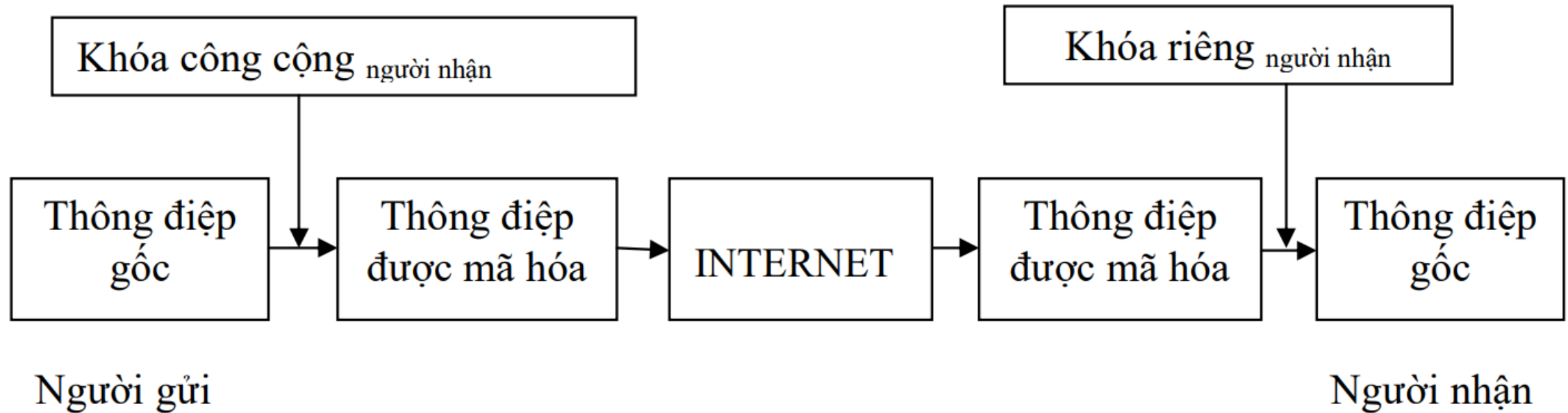
4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Kỹ thuật mã hóa đơn sử dụng một khoá khoá bí mật:



4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Kỹ thuật mã hóa kép sử dụng khoá công khai và khóa bí mật



4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Chữ ký số (Digital signature)

Về mặt công nghệ, chữ ký số là một thông điệp dữ liệu đã được mã hóa gắn kèm theo một thông điệp dữ liệu khác nhằm xác thực người gửi thông điệp đó. Quá trình ký và xác nhận chữ ký số như sau:

Người gửi muốn gửi thông điệp cho bên khác thì sẽ dùng một phần mềm rút gọn thông điệp dữ liệu điện tử, xử lý chuyển thông điệp dữ liệu điện tử thành một “thông điệp tóm tắt” (Message Digest), thuật toán này được gọi là thuật toán rút gọn (hash function).

Người gửi mã hoá bản tóm tắt thông điệp bằng khóa bí mật của mình (sử dụng phần mềm bí mật được cơ quan chứng thực cấp) để tạo thành một chữ ký điện tử. Sau đó, người gửi tiếp tục gắn kèm chữ ký điện tử này với thông điệp dữ liệu ban đầu.

4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Chữ ký số (Digital signature)

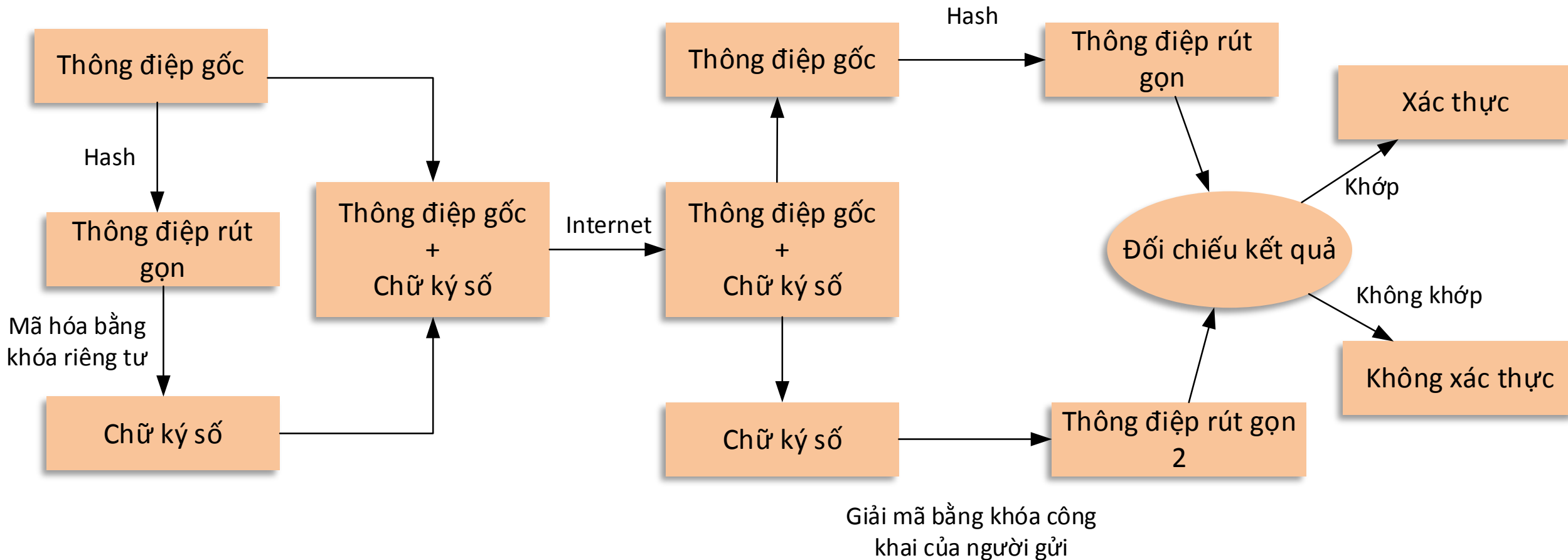
Sau đó gửi thông điệp đã kèm với chữ ký điện tử một cách an toàn qua mạng cho người nhận.

Sau khi nhận được, người nhận sẽ dùng khoá công khai của người gửi để giải mã chữ ký điện tử thành bản tóm tắt thông điệp. Người nhận cũng dùng rút gọn thông điệp dữ liệu giống hệt như người gửi đã làm đối với thông điệp nhận được để biến đổi thông điệp nhận được thành một bản tóm tắt thông điệp. Người nhận so sánh hai bản tóm tắt thông điệp này. Nếu chúng giống nhau tức là chữ ký điện tử đó là xác thực và thông điệp đã không bị thay đổi trên đường truyền đi.

Ngoài ra, chữ ký số có thể được gắn thêm một “nhãn” thời gian: sau một thời gian nhất định quy định bởi nhãn đó, chữ ký số gốc sẽ không còn hiệu lực, đồng thời nhãn thời gian cũng là công cụ để xác định thời điểm ký.

4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Chữ ký số (Digital signature)



4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Phong bì số (Digital Envelope)

Tạo lập một phong bì số là một quá trình mã hoá sử dụng khoá công khai của người nhận (phần mềm công khai của người nhận, phần mềm này cũng do cơ quan chứng thực cấp cho người nhận, và được người nhận thông báo cho các đối tác biết để sử dụng khi họ muốn gửi thông điệp cho mình).

Khóa bí mật này được dùng để mã hoá toàn bộ thông tin mà người gửi muốn gửi cho người nhận, khóa này đảm bảo chỉ có duy nhất người nhận là người mở được thông điệp để đọc.

Vì duy nhất người nhận là người nắm giữ khóa tương ứng để giải mã (phần mềm bí mật hay khóa bí mật, khóa này cũng do cơ quan chứng thực cấp cho người nhận).

4.4.2 Biện pháp đảm bảo an toàn cho GD TMĐT

Chứng thư số (Digital Certificate):

Chứng thư điện tử xác minh rằng người cầm giữ mã khóa công cộng hoặc mã khóa bí mật chính là người chủ của mã khóa đó.

Bên thứ ba, Cơ quan chứng thực, sẽ phát hành chứng thư điện tử cho các bên tham gia.

Nội dung Chứng thư điện tử bao gồm: tên, mã khoá công khai, số thứ tự của chứng thực điện tử, thời hạn hiệu lực, chữ ký của cơ quan chứng nhận (tên của cơ quan chứng nhận có thể được mã hoá bằng mã khoá riêng của cơ quan chứng nhận) và các thông tin nhận dạng khác.

Các chứng thư này được sử dụng để xác minh tính chân thực của website (website certificate), của cá nhân (personal certificate) và của các công ty phần mềm (software publisher certificate).

4.4.3 Biện pháp đảm bảo an toàn cho hệ thống TMĐT

- **Tường lửa**
- **Mạng riêng ảo (VPN)**
- **HTTPS và chứng chỉ SSL**
- **Sử dụng password đủ mạnh**
- **Bảo mật website và máy chủ**
- **Phòng chống virus**
- **Giải pháp an ninh nguồn nhân lực:** Các doanh nghiệp cần lưu ý mọi nhân viên trong doanh nghiệp mình ý thức về vấn đề an ninh mạng và những nguy cơ tấn công doanh nghiệp có thể chịu trong trường hợp thiếu kinh nghiệm hoặc thiếu sự lưu tâm đúng mức từ phía các nhân viên.
- **Giải pháp về trang thiết bị an ninh mạng:** Sử dụng các thiết bị kiểm soát việc ra vào trụ sở làm việc